

QK2 PSBT Checklist

The ordered sign-or-reject pipeline for a **PSBT v0 profile** over the selected **native P2WSH 2-of-3** wallet `wsh(sortedmulti(2,A,B,C))` , across **both microSD and QR transports**, checks classified fatal-fraud / fatal-policy / warning — plus a *reference* attack corpus (embit-built, cross-checked, not production-tested). A design profile against a selected product direction, not a validated implementation.

PROJECT STATUS — REFERENCE PROFILE, NEGATIVE CORPUS INCOMPLETE

This is a candidate **PSBT v0** validation profile; v2 is deferred. The corpus establishes reference/cross-check consistency (levels 1–2), not production conformance — no C parser exists, and the negative corpus (§03) is not yet complete. "MUST SIGN / MUST REJECT" below describe the intended profile, not a tested signer.

STAGES	CORPUS WALLET	TRANSPORTS	ORACLE	SIZE CAP	DATE
S0 → S9	wsh 2-of-3 (selected)	microSD + QR	embit cross-check	2 MiB	2026-08-17

1. [Verdict taxonomy](#)

2. [The ordered pipeline \(S0–S9\)](#)

3. [Attack corpus \(cross-checked\)](#)

4. [The signing gate](#)

5. [Conformance & fixtures](#)

Three verdicts, and the rule that a warning never changes what gets signed

ColdCard's core discipline: separate proofs of fraud from policy choices from ambient facts. Mixing them causes warning fatigue (over-blocking legitimate flows) or hidden theft (under-warning). QK2 adopts three classes.

VERDICT	BEHAVIOUR	EXAMPLES
FATAL-FRAUD	Distinct alarming title (e.g. "Change Fraud"), discards the PSBT , dead-end screen with no Back, history flushed.	bad change script · amount mismatch · duplicate inputs
FATAL-POLICY	Blocks signing. Thresholds are fixed conservative product policy , not user-tunable in the ordinary UI (the fee ceiling is not a settings dial); any override lives behind a justified advanced path. Clear reason shown.	fee over abs ceiling · SIGHASH_NONE · uncomputable fee · mixed policy
WARNING	Counted at the top of the approval story, shown, does not block. Never alters signed bytes.	high fee / rate (versioned) · OP_RETURN present · unusual owned path

STATELESSNESS CAVEAT – CARRIED FROM THE BLUEPRINT

ColdCard's durable CVE-2020-14199 defence is a **persistent outpoint→amount cache**, which a stateless device cannot keep. Requiring the **full previous transaction for every input** (S3) is a *conservative QK2 policy* that BIP-174 permits — it is **not** a universal PSBT requirement — and it has costs: some coordinators omit non-witness UTXOs, and full prevtxs enlarge the 2 MiB / RAM budget. Document those interop and memory consequences, weigh them against the precise repeated-signing attack being mitigated, and if the shortcut is ever allowed, compensate with a card-sealed spend-set commitment.

Ordered stages – signing cannot begin until every gate passes

Order matters: cheap structural rejects run before expensive derivation; the approval hash is bound before any human interaction; the re-check happens with no yield before the first signature. Each check below carries its verdict class.

S0 Intake & bounds (microSD + QR)

FATAL **Two required transports, one intake model:** both **microSD** (the lower-risk first path) and **QR** are required PSBT transports. Whichever the source, assemble the object *once* into a single **immutable RAM buffer**, then parse via bounded offset views (`(offset, len)`) over that immutable buffer — never parse in place on removable media, never re-read the card mid-parse, and never re-open the QR stream after assembly. The bytes never change under the parser after assembly.

FATAL **Hard 2 MiB cap enforced at copy-in / stream-assembly:** abort the moment the accumulated object exceeds the cap before it is admitted to the buffer. Target RAM budget $\approx$ the ≤ 2 MiB immutable buffer plus bounded parse metadata (offset/len views, not materialised sub-objects) — a few tens of KiB of working state.

FATAL **QR-mode lock:** the PSBT-capture camera mode accepts *only* a PSBT QR stream — it never auto-detects a seed/address QR or accepts an arbitrary QR class. The v1 QR framing is **selected — BBQR file type P , uncompressed base32** (the one framing already supported by the reviewed SeedSigner and COLDCARD): **no UR2 / Specter / SeedQR / generic-QR autodetection** in the production PSBT scanner. QR performance on the fixed mechanics is still a Gate-A blocker — the format is chosen, the throughput is not yet validated.

FATAL **QR-stream negative cases** all fail closed with a clean error: a malformed/undecodable fragment; a fragment whose framing type differs from the stream's (mixed-type); a duplicated or out-of-window fragment (replay); an oversize fragment or a total that would breach the 2 MiB cap; and a stream that ends incomplete (missing fragments / timeout). No partial or reassembled-with-gaps PSBT is ever admitted.

FATAL **microSD carries binary PSBT v0 only** (a `.psbt` file, magic `psbt\xff`): hex and base64 are **rejected, not auto-detected**. There is **no input→output encoding/transport symmetry** — the return representation and transport are chosen by tier/coordinator policy (binary PSBT / BBQR / final raw tx), never mirrored from whatever the input happened to be.

FATAL Corrupt/unreadable $\equiv$ absent card / aborted scan — no on-device FS recovery, no partial-stream salvage.

QR IS A HARDWARE/SYSTEM BLOCKER – SELECTED DIRECTION, NOT VALIDATED

QR framing, capture, animated reassembly, screen export, RAM headroom, and throughput remain an **open HW/system-validation BLOCKER** on the existing enclosure / optics / 320×240 display; **no mechanical redesign is authorized**. microSD is the lower-risk first path and must stand alone if QR performance fails the benchmark. Treat every QR-transport rule here as a validation target, not a shipped capability.

S1 Structural parse

FATAL Magic `psbt\xff` ; parse via bounded offset views over the S0 immutable buffer (store `(offset, len)` into that buffer, never materialise the whole tx or copy sub-objects out).

FATAL Hard caps before buffering: MAX_INPUTS, MAX_OUTPUTS, MAX_SIGNERS=15, MAX_PATH_DEPTH=12; duplicate-key rejection.

FATAL **v1 is a PSBT v0 profile:** reject BIP-370 v2 global fields (deferred), and reject Taproot fields (BIP-371) as out of scope. If v2 is later required by the interop matrix, add it with strict v0/v2 mutual-exclusion.

GUARD One fail-closed exception boundary wraps all parsing → clean error screen, state zeroised (never a "Yikes" crash).

S2 Bind (anti-TOCTOU)

BIND Build an **immutable canonical review object** and bind the approval to it: a hash of the exact unsigned transaction, the relevant UTXO/script facts, the resolved policy identity, and the sighash decisions — *not* merely a hash of the serialized bytes. Keep raw-byte integrity as a separate check. (Re-verified at S9.)

S3 Inputs

FRAUD Per input, recompute `calc_txid(non_witness_utxo) == prevout.hash` .

FRAUD **Amount provenance:** require the full previous transaction for every input; a bare `witness_utxo` is insufficient (statelessness caveat). This is the CVE-2020-14199 defence.

FRAUD Reject duplicate `(txid, vout)` prevouts.

FATAL **Precise already-signed rule** (not "reject any partial signature"): a 2-of-3 PSBT *may* arrive already carrying a valid signature from another registered cosigner (A, B, or C) — but do **not** assume every ordinary QK2 transaction arrives partially signed; an unsigned PSBT is the common case. Reject only conflicting, malformed, duplicate, or *already-signed-by-a-factor-QK2-is-about-to-use* input state. A pre-existing signature from a registered cosigner whose factor is *not* being loaded this session is **cryptographically verified against the exact sighash and that cosigner's authorized pubkey**; if valid it is **preserved byte-for-byte** (invalid, conflicting, or wrong-sighash ones are rejected). QK2 adds only the one authorized missing signature per factor it holds.

FATAL Reject mixed input policies (heterogeneous script types). **v1 scope:** collaborative transactions (coinjoin/payjoin, foreign inputs) are *out of scope for v1*: v1 signs only single-policy transactions over the registered wallet.

FATAL **Foreign inputs are rejected in v1:** reject any input the device cannot fully attribute to the registered wallet and render — there is no "allowed with a warning" path. Zero-fingerprint inputs that are ours are resolved by derive-and-compare (never a dead end); inputs that remain unattributable are fatal.

S4 **Outputs & change**

FRAUD An output is change **only if** `descriptor.owns(output)` holds — reconstruct the full witness script from the selected policy's **complete key set** (all three xpubs A/B/C of the sealed `sortedmulti(2,...)` 2-of-3 descriptor, lexicographically ordered; the historical 2-of-2 regression fixture uses both of its two keys), never a path-pattern match on our own key alone. Distinct `FraudulentChange` class; **no skip button**.

WARN Owned-but-anomalous path (huge index, off-pattern branch) → "funds return to your seed at an unusual path", not silent change.

SHOW Every non-change output is a recipient; its full value shows as leaving the wallet.

S5 **Fee**

FRAUD $\text{fee} = \sum \text{in} - \sum \text{out}$ under **checked 64-bit money-range arithmetic**; negative or uncomputable ("outputs worth more than inputs", or any overflow) is fatal.

SHOW Display the **absolute fee (sats) and the fee rate (sat/vB)** wherever computable — a percentage-of-spend threshold alone is not adequate (it hides a huge fee on a small spend).

WARN **No universal "10% of spend" fatal rule** — consolidations and small sends make that heuristic unreliable, so it is retired. An unusually high fee or fee rate raises a **counted, versioned warning** (thresholds carry a policy version so they can evolve without a silent

behaviour change); it is shown, it does not block.

FATAL A single **conservative absolute emergency ceiling** (an absolute-sats cap catching only catastrophic fees, never a percentage of spend) fails closed. It is **fixed conservative product policy, not a user-tunable dial in the ordinary UI**; any relaxation is an advanced override reachable only through a justified, deliberately friction-full path.

FATAL **Uncomputable fee fails closed** — if any input amount is unverifiable, name the input indices and block; never display 0%.

S6 Sighash

FATAL Default-deny `SIGHASH_NONE`, `SIGHASH_SINGLE`, and any `|ANYONECANPAY`; unknown flag values fatal.

FATAL Consolidations (all outputs are change) require `ALL` on every input; assert no `SINGLE`-with-missing-output edge case can be signed.

EMIT Strip redundant explicit `SIGHASH_ALL` from the output PSBT.

S7 Script & output anomalies

WARN `OP_RETURN`: parse push opcodes correctly (direct push vs `OP_PUSHDATA1/2` — never a fixed `data[3:]` slice); `>1 OP_RETURN` or payload `>83` bytes warns.

SHOW **A recognised ordinary external recipient is normal**: a standard script type (`P2WPKH`, `P2WSH`, `P2SH`, `P2TR/bech32m`, ...) the device can *fully render* and that simply is not our wallet is a routine payment — **rendered at full length and NOT warned merely for being external** (paying an outside address is the ordinary case; a warning here is warning fatigue). It surfaces as a normal recipient line in S8, exactly like any other spend.

FATAL (v1) **Unknown or unrenderable output scripts are FATAL in v1**, not a routine warning — a non-standard, malformed, or otherwise un-decodable script the device cannot render exactly is not signed. A signer that can't show precisely what an output pays must refuse. Non-`OP_RETURN` zero-value outputs warn.

WARN Surface RBF (BIP-125) status.

S8 Human review (scroll-gated)

UIV Overview (spend/change/fee + I/O pictogram) → explicit arithmetic (in — recipients — fee — change) → each recipient's **full** address

UX Overview (spend/change/fee + fee prototyping) / explicit arithmetic (in recipients + fee = change) / each recipient's full address in 4-char groups over two lines → each change output with path + verification badge → raw OP_RETURN → the counted warning list.

GATE The approve control appears only after the user scrolls the *entire* address of every output.

S9 Re-bind & sign

FRAUD Re-verify the **S2 review-object identity** (the immutable canonical review object bound at S2) with **no interactive yield** before the first sighash; wipe and abort on mismatch ("Transaction modified").

SIGN v1 signing is **exact deterministic ECDSA (RFC-6979)** on the terminal (pinned libsecp256k1) with **low-S** and **verify-before-release**; card signature behaviour is a Gate-B capability to specify and test. **A key adds exactly ONE signature per input**; QK2 as a *session* may add **up to two** signatures because it has loaded **two of the three factors** — e.g. Seed-A (recovered by decrypting the A1 document with the A2 key released by the bearer card) and the card's own Seed-B (or Seed-C). Each loaded factor signs once, and **every produced signature is checked against its pubkey before any leaves the device**. This clears the 2-of-3 threshold on its own for the normal A1+B (or A1+C) session; a B+C session likewise contributes the card factor(s) it holds. low-S is required (sourced independently; BIP-146 is withdrawn). **low-R is optional** (not canonical, not a uniform-71-byte requirement). Caller-controlled-nonce anti-exfil is a deferred, optional future hardening — not mandatory in v1, and a one-shot JavaCard ECDSA likely cannot provide it.

EMIT **A completed local 2-of-3 session meets the threshold**, so QK2 **finalizes the P2WSH witness** (independently tested witness/signature ordering) and reparses/verifies the **final raw transaction** before release. **Every completed local 2-of-3 session returns that final raw transaction**; Standard/Simple and Inheritance tiers additionally return a **finalized PSBT** where the selected coordinator needs one, and Quantum Shelter returns the raw transaction only (see Q-SHELTER OUT). The emitted PSBT uses deterministic export with an **explicit unknown-field policy** — the exact preserve / reject / normalize behavior: **PRESERVE** every unknown and proprietary key-value pair verbatim in the output (byte-for-byte key *and* value, unless S1 already gave that field a documented rejection); **ADD** no proprietary fields of QK2's own beyond the signature records it is authorized to place; the **only** normalization is stripping a redundant explicit `SIGHASH_ALL` (per S6). **Reconciling "canonical order" with byte-for-byte preservation**: the two do not conflict because they govern different things. "Canonical order" is only the *placement* rule — QK2 serialises each map's records in BIP-174 canonical key order (ascending by keytype, then keydata), which is a total order on *where* a record sits, and it applies uniformly to preserved unknown records too. Preservation is about *content* — each preserved record's key bytes and value bytes are emitted unchanged. So a preserved unknown pair is placed at its deterministic canonical position but never has its bytes rewritten; nothing is dropped, and no record's value is reordered internally or altered. (If a source map was already canonically ordered, output byte-order is identical.) Fixed `<name>-signed.psbtx`.

SD LIFECYCLE The microSD intake was a read-only mount; emitting is a **distinct write phase** — read-only mount and "emit to card" cannot happen at once. Sequence: read-only intake → unmount/power-cycle as needed → explicit remount for write → write to **temp file** → `fsync` →

validate/read-back verify → **atomic rename where available** → cleanup → safe removal. The signed result is a new object; the input file is untouched and any incomplete output is detectably invalid or ignored.

QR OUT **QR is also an output transport:** the signed result may be rendered as an animated PSBT QR stream using the *one* selected framing — **BBQr** (type `P`, uncompressed) — never a mix, mode-locked to display-only. This inherits the same **HW/system-validation BLOCKER** as QR intake (framing / screen export / animation cadence / 320×240 optics, no mechanical redesign authorized) — **SELECTED** direction, not a validated capability; microSD remains the lower-risk first path.

Q-SHELTER OUT **Quantum-Shelter (Deep Cold) output policy:** in Quantum Shelter mode the device **prefers to emit a FINALIZED RAW TRANSACTION** — the completed, network-ready tx with *no* xpub/origin/derivation metadata returned to the online side — so the online coordinator never receives account-level key material. If a standards PSBT must be emitted instead, it goes out under an **explicit metadata-minimizing policy** (strip xpub/origin/unknown-descriptor metadata beyond what finalization requires; addresses only online). This is a per-kit-tier product policy, not an implemented mode.

03 ATTACK CORPUS

The 2-of-3 corpus – the three signing pairs that must sign, plus the attacks that must not

The **selected wallet is native P2WSH 2-of-3** `wsh(sortedmulti(2,A,B,C))`, so the conformance corpus is built against it, using `embit` (the `SeedSigner` library) as a cross-check oracle. The six attack fixtures below were originally generated against the *historical 2-of-2* wallet and are **retained only as a regression fixture family**; each was parsed back and *shown by cross-check* to carry its malicious property. The mutations transfer directly onto the 2-of-3 wallet and **must be regenerated against it** before any conformance claim. Full base64 fixtures ship in `qk2_psb_t_corpus.json`.

Required 2-of-3 must-sign fixtures (SELECTED direction, not yet built): the suite must carry a valid

MUST SIGN case for **each of the three valid signing pairs — A+B, A+C, and B+C** (a threshold met by any two factors), plus **factor-rotation sweeps** (e.g. C lost → A+B rotates C; the sweep from the old

policy to the rotated one). Because 2-of-3 PSBTs can legitimately arrive already carrying one cosigner's valid signature, each pair fixture must also appear in a **pre-signed-by-the-other-factor** variant where QK2 adds only the one authorized missing signature and preserves the existing cosigner signature byte-for-byte — without assuming ordinary PSBTs arrive partially signed (the unsigned case is primary). Both families — the 2-of-3 primary corpus and the 2-of-2 regression corpus — are required before any conformance claim.

```
-- SELECTED wallet under test: native P2WSH 2-of-3 (reference computation, not canonical) --
descriptor wsh(sortedmulti(2,[2fae9711/48h/0h/0h/2h]xpub6E4Ac...MuourfoYr/<0;1>/*,  A
                                [72a14ab8/48h/0h/0h/2h]xpub6ETbd...8CRPgctyufF/<0;1>/*,  B
                                [badaa8ff/48h/0h/0h/2h]xpub6F...C-key-elided.../<0;1>/*))#kuyqfyj3  C
recv /0/0  bc1qecahkw0srs8xpmgwqya49qtknxwvkwrt0ky4jds52scsw4etmd6s5s93pr

-- HISTORICAL 2-of-2 (regression fixture only, NOT the shipping wallet) --
descriptor wsh(sortedmulti(2,[2fae9711...]A,[72a14ab8...]B))#w9nvs8vx

-- BASELINE must-sign: one factor = one signature; the QK2 SESSION adds up to TWO --
-- signatures because it loaded two of {A,B,C} this session (fee 2000 sats). --
cHNidP8BAKYCAAAAAtpbkd1clVD6... (2-of-2 regression blob; regenerate per-pair for 2-of-3 - qk2_psbt_corpus.json)
```

VECTOR	MUTATION APPLIED	CAUGHT BY	VERDICT	VERIFIED PROPERTY
SIGN-A+B	2-of-3 spend, A1+B session (decrypt A via A2, sign A & B) to build	—	MUST SIGN	threshold_met=T · sigs_added=2 · change_owned=T
SIGN-A+C	2-of-3 spend, A1+C session (B lost path) to build	—	MUST SIGN	threshold_met=T · sigs_added=2 · change_owned=T
SIGN-B+C	2-of-3 spend, B+C session (A1 lost, A bypassed) to build	—	MUST SIGN	threshold_met=T · sigs_added=2 · change_owned=T
SIGN-PRESIGNED	arrives with C's valid sig; A1+B adds only the missing one to build	S3 preserve	MUST SIGN	foreign_sig_preserved=T · new_sigs=2

ROTATE-C	factor-rotation sweep: A1+B signs, C reissued to new key to build	—	MUST SIGN	policy_v→v+1 · new_C_fp≠badaa8ff
BASELINE-2of2	historical 2-of-2 regression fixture, one factor signed	—	MUST SIGN	change_owned=T · recip_owned=F · fee=2000
AMOUNT-LIE	drop prevtx; witness_utxo 30000 (true 100000)	S3 provenance	FATAL-FRAUD	has_prevtx=False · embed fee=-68000
FRAUD-CHANGE	output1 pays attacker, carries change metadata	S4 owns()	FATAL-FRAUD	out1_owned_by_wallet=False
DUP-INPUT	input2 repeats input0 outpoint (3 inputs)	S3 dup-prevout	FATAL-FRAUD	has_duplicate_outpoint=True
SIGHASH-NONE	input0 sighash_type = 0x02	S6 default-deny	FATAL-POLICY	sighash_type=2
ABSURD-FEE	change stripped → fee ≈ entire input (catastrophic)	S5 abs-ceiling	FATAL-POLICY	fee≈Σin · breaches abs emergency ceiling (not a % rule)
FEE-UNKNOWN	input1 has no prevtx and no witness_utxo	S5 fail-closed	FATAL-POLICY	input1_utxo_missing=True

NOTE ON THE AMOUNT-LIE VECTOR

This fixture understates so far that the fee goes negative (also fatal at S5). The *canonical* two-pass CVE-2020-14199 attack keeps the transaction balanced so the fee looks normal on each pass — which is exactly why the defence is **provenance at S3** (require the prevtx and verify its txid), not fee-sanity at S5. A device that trusts `witness_utxo` passes the fee check and still loses funds.

Corpus still to add before ship

The six above are a *reference* corpus covering the highest-severity classes; each was shown by cross-check to carry its property (not production-tested). **Before any "conformance" claim**, the negative corpus must also add: duplicate map keys and **non-minimal CompactSize** encodings; integer

overflow/underflow and pathological counts/lengths; v0/v2 cross-field confusion; **both UTXO records present but inconsistent**; invalid witness scripts/origins/descriptor paths; pre-existing valid *and* invalid signatures; unknown/proprietary field round-trip; **malformed DER, high-S, wrong-sighash** signatures; output/address render vectors; **power interruption at every SD and signing state**; and fuzzing with sanitizers under the target memory ceiling. Mixed-input-policy, already-signed re-presentation, SINGLE-with-missing-output, oversized/multiple OP_RETURN, and zero/blank fingerprints (BlueWallet-class) round it out. It must further add the **2-of-3 must-sign families** (A+B, A+C, B+C, the pre-signed-by-another-factor variants, and factor-rotation sweeps) that supersede the retained 2-of-2 regression set; **QR-transport negatives** (malformed fragment, mixed framing type, replayed/out-of-window fragment, oversize fragment, incomplete/timed-out stream) on both intake and output; and **Quantum-Shelter output** vectors that assert a finalized raw transaction carries no xpub/origin metadata (and that any standards-PSBT fallback honors the metadata-minimizing policy). QR throughput itself remains a hardware/system blocker to be benchmarked, not a corpus item.

04 THE SIGNING GATE

Why the review object is bound before the human, and re-checked after

Between S2 and S9 the PSBT sits in RAM for the seconds-to-minutes a user reads the approval screens, and the card interface is live. Without binding the approval to the immutable canonical review object, an attacker who swaps the microSD or exploits a buffer bug can make what is signed differ from what was approved.

```
S2  r := review_object(unsigned_tx, utxo/script facts, policy id, sighash)    immutable canonical review object
S8  ... user reviews, scrolls every address, approves ...
S9  assert review_object_identity() == r                                     re-check the review object, no yield in between
```

```

on mismatch: psram_wipe(); abort("Transaction modified")
else: for f in session_factors: sign_once(f)    two of {A,B,C} loaded ⇒ up to 2 sigs
      verify_all(); finalize(); emit()          sigs checked; threshold met ⇒ final raw tx returned

```

ALWAYS-SAFE ABORT

Card removal or the inactivity timeout aborts and wipes at any stage. Battery pull is safe precisely because all secrets are RAM-only and the original input PSBT is never mutated: the signed result is a new object written via temp-file → flush/ fsync → validate → atomic rename where available → cleanup, so an interruption before that sequence completes leaves the original untouched and any incomplete output detectably invalid (or ignored). A signature interrupted before S9's emit is simply recomputable from the untouched input.

05 CONFORMANCE

What an implementation must satisfy

1. Run stages **in order**; signing begins only after all gates pass and the S9 re-check succeeds.
2. Sign a valid must-sign fixture for **every 2-of-3 signing pair (A+B, A+C, B+C)**, including the pre-signed-by-another-factor and factor-rotation variants, over both microSD and QR; reject all attack fixtures with the tabulated verdict class and a distinct title. (The 2-of-2 fixture is a retained regression, not the shipping wallet.)
3. Classify every finding as fraud / policy / warning per §01; a warning must never alter the signed bytes.
4. Enforce the statelessness rule: require full prevtx for every input (or card-sealed spend-set commitment). No witness-only shortcut.
5. Change verification is mandatory with no skip path; distinguish **recognized ordinary external recipients** (a standard script the device can fully render but that is not our wallet) — a routine

recipients (a standard script the device can fully render but that is not our wallet — a routine payment, rendered at full length and *not* warned merely for being external) from **unknown or unrenderable output scripts** (FATAL in v1) — do not lump them together, and do not treat paying an outside address as an anomaly.

6. Keep the validation core UI-free and headless-testable; wire the corpus into CI so a regression that would sign an attack fixture fails the build.
7. Fuzz the parser off-target with malformed streams behind the S0/S1 caps and the single exception boundary.
8. Accept and emit over **both microSD and QR** (microSD binary PSBT v0 only, no hex/base64 autodetect; the one selected QR framing, **BBQR**); fail every QR-stream negative closed (malformed / mixed-type / replay / oversize / incomplete). QR throughput is a HW/system blocker to be benchmarked separately — microSD must stand alone if QR fails.
9. Return the **final raw transaction for every completed local 2-of-3 session** (and a **finalized PSBT** where the selected tier/coordinator needs one); verify existing partial signatures and add only the required signature records. In **Quantum-Shelter mode**, emit *only* the **finalized raw transaction** with no xpub/origin metadata; any standards-PSBT fallback must honor the explicit metadata-minimizing policy (addresses only online).

FIXTURES — REFERENCE SET DELIVERED, 2-OF-3 CORPUS TO REGENERATE

`qk2_psbt_corpus.json` currently holds the **historical 2-of-2 regression set** (one must-sign + six attacks) with per-vector expected verdict, catching stage, and a SHA-256 of the serialised PSBT. `qk2_psbt_corpus.py` — the generator (imports the QKEC-1 reference; uses embit as oracle) — is the tool to **regenerate the primary 2-of-3 corpus** (the A+B / A+C / B+C must-sign families, pre-signed and rotation variants, and the transferred attack mutations) with the same verify-the-property discipline before any conformance claim.

QK2 PSBT Checklist · working draft v1 · 2026-08-17

Corpus built against the candidate QK2 Standards Register descriptor from the reference QKEC-1 seeds; descriptor and addresses cross-reproduced by `embit`; every attack fixture parsed back and asserted to carry its malicious property. Validation order and classes follow ColdCard's `shared/psbt.py` / `auth.py` and the documented CVE history. Companion to the QuietKey QK2 Blueprint, the QKEC-1 Specification, and the QK2 Standards Register.